Resumen de Hallazgos — Auditoría Móvil DIVA Android

Práctica de laboratorio 06 — Seguridad en Aplicaciones | Paquete: jakhar.aseem.diva | Entorno: MuMuPlayer (Android 15, x86_64)

ID	Componente afectado	Procedimiento	Evidencia	Impacto	Corrección propuesta
D01	LogActivity.java:56	Ingreso de tarjeta de prueba 4111111111111111 en 'Insecure Logging' y captura de logcat.	logcat: Log.e('diva-log', ... PAN completo)	App con permiso de logs o acceso ADB recupera datos financieros sin interacción.	No loguear el valor; usar referencia no reversible (ej. últimos 4 dígitos).
D02	HardcodeActivity.java:44	Decompilación con JADX; ingreso de la clave hallada 'vendorsecretkey' en el campo.	Toast 'Access granted!'	Decompilación trivial revela el secreto; compromete cualquier control basado en él.	No embeber secretos en el cliente; validar contra backend.
D03	InsecureDataStorage1Activity.java	Guardado de credenciales de prueba; lectura de SharedPreferences vía run-as.	shared_prefs/...xml en texto plano	Acceso root/mismo UID expone credenciales en claro.	Usar EncryptedSharedPreferences (Jetpack Security).
D04	InsecureDataStorage2Activity.java	Guardado de credenciales de prueba; consulta SQLite vía run-as + sqlite3.	tabla myuser en texto plano	Acceso root/mismo UID expone credenciales en claro desde la BD.	Cifrar BD (SQLCipher) o columnas sensibles con clave en Keystore.
D05	SQLInjectionActivity.java:70	Payload x' OR '1'='1 en campo de búsqueda; verificación contra la BD sqli.	3 usuarios y tarjetas expuestos con 1 query	Bypass total de filtro; exposición de credenciales y datos financieros de todos los usuarios.	rawQuery parametrizado (?) en vez de concatenación.
D06	InsecureDataStorage3Activity.java	Guardado de credenciales; lectura de archivo temporal world-readable vía run-as.	archivo uinfo*tmp en texto plano	Archivo con permisos abiertos deliberadamente; legible por otras apps/root.	No usar setReadable/setWritable(true); cifrar con EncryptedFile.
D07	InputValidation2URISchemeActivity.java	WebView con JS habilitado; carga de file:///.../shared_prefs/...xml.	WebView renderiza contenido del archivo interno	Lectura arbitraria de archivos del sandbox de la app vía esquema file://.	Restringir loadUrl a https; deshabilitar acceso a file:// en WebView.
D08	APICredsActivity (manifest, exported=true)	Invocación directa del intent-filter VIEW_CREDS sin abrir la app (am start -a).	Pantalla de credenciales API mostrada directamente	Cualquier app de terceros extrae credenciales de vendor sin interacción del usuario.	exported=false o permiso signature-level.
D09	APICreds2Activity.java	Invocación directa de VIEW_CREDS2 con extra check_pin=false (bypass).	Credenciales API Tveeter mostradas sin PIN	Control de acceso basado en dato enviado por el cliente; validación inexistente en servidor.	Validar PIN en backend; nunca decidir con un extra del intent.
D10	NotesProvider (manifest, exported=true)	Consulta directa al ContentProvider vía 'content query' sin pasar por la app.	6 notas privadas expuestas	Lectura (y potencial escritura) de datos personales por cualquier app instalada.	exported=false o permiso signature-level + validar caller.

Correcciones aplicadas

Corrección A (Insecure Logging): LogActivity.java — se reemplazó el log del número de tarjeta completo por una referencia enmascarada (últimos 4 dígitos). Verificado: log ya no expone el PAN; funcionalidad intacta.

Corrección B (SQL Injection): SQLInjectionActivity.java — se reemplazó la consulta concatenada por rawQuery parametrizado. Verificado: payload x' OR '1'='1 ya no retorna filas; búsqueda legítima (admin) funciona igual.